Nätverkssäkerhet

Föreläsning 5 – Brandväggar (Kapitel 8-10)

Planering

Vecka	Dag	Moment
35	Mån	~~**Föreläsning –** Kursintroduktion & introduktion till nätverkssäkerhet~~
	-	~~**Videoföreläsningar –** Säkra upp enheter & AAA~~
	Mån /Tis	~~**Laboration 1**~~
36	Mån	~~**Forts. Laboration 1**~~
	Tis	~~**Dugga 1** (09.00)~~
	Tor	~~**Gästföreläsning Fortinet**~~
	Fre	**Föreläsning –** Introduktion till brandväggar
37	Mån	**Laboration 2**
	Tis	**Dugga 2** (09.00)
	Tis	**Föreläsning** – IDS/IPS
38	Mån	**Laboration 3**
	Tis	**Dugga 3** (09.00)
	Tis	**Gästföreläsning JSC (09.30) & Föreläsning** – LAN- och endpoint-säkerhet
	Fre	**NFK-introduktion**
39	Mån	**Laboration 4**
	Tis	**Dugga 4** (09.00)
	-	**Videoföreläsning** – Kryptografi
	Tor	**Föreläsning** – VPN
40	Mån	**Laboration 5**
	Tis	**Dugga 5** (09.00)
	Tis	**Föreläsning** – Extrapass
41	Ons	**Laboration 6 & Redovisningar av Laboration 6**
42	-	**Tentavecka**

Brandväggar - från ACL till ZPF till ASA (and beyond)

- Brandväggar används för att separera olika säkerhetszoner
- De första brandväggarna var enkla access-listor (ACL)
- Sedan kom **stateful**-brandväggar:
  - Established-ACL
  - Reflexive
  - CBAC (Context-Based Firewalls)
  - ZPF (Zone-Based Policy Firewall)
  - Dedikerade brandväggslösningar (ASA, Firepower, CheckPoint, FortiGate, etc.)

Access-listor (ACL)

Access Control List (ACL)

- Har vi gått igenom tidigare!
- **Tänk på:**
  - Ordningen spelar roll
    - Alltid den mest specifika högst upp
  - En per…
    - Riktning (in/out)
    - Protokoll
    - Interface
  - Implicit deny

IPv6-ACL

- Fungerar ungefär på samma sätt som i IPv4
- **Skillnad:** Alla accesslistor i IPv6 måste ha namn
- Glöm inte att tillåta **Neighbor Discovery** på lokala interface vid *deny ipv6 any any*

```
R1(config)# ipv6 access-list SERVERS
R1(config-ipv6-acl)# permit tcp any host 2001:6b0:18:70:164 eq 80
R1(config-ipv6-acl)# permit icmp any any nd-na
R1(config-ipv6-acl)# permit icmp any any nd-ns
R1(config-ipv6-acl)# deny ipv6 any any
R1(config-if)# ipv6 traffic-filter SERVERS out
```

- Alternativ: Skippa *deny ipv6 any any*

Stateful Packet Inspection

- Vad är SPI?
- **”Established”**
  - Är den enklaste formen av *Stateful Inspection* som finns
  - Kollar endast om ACK-flaggan (eller RST) i TCP-sessionen är satt, ingen kontroll av UDP eller ICMP
- **Reflexiv ACL**
  - Kontrollerar mer än bara flaggor i TCP-sessioner, därför svårare att komma runt
  - Håller koll på hela sessionen, inte bara lösa paket. Skapar hål i befintlig ACL
  - Hanterar även UDP och ICMP
- ZPF, ASA, FortiGate, etc. har ”riktig” SPI (kontroll på lager 7)

Brandväggar

Brandväggar

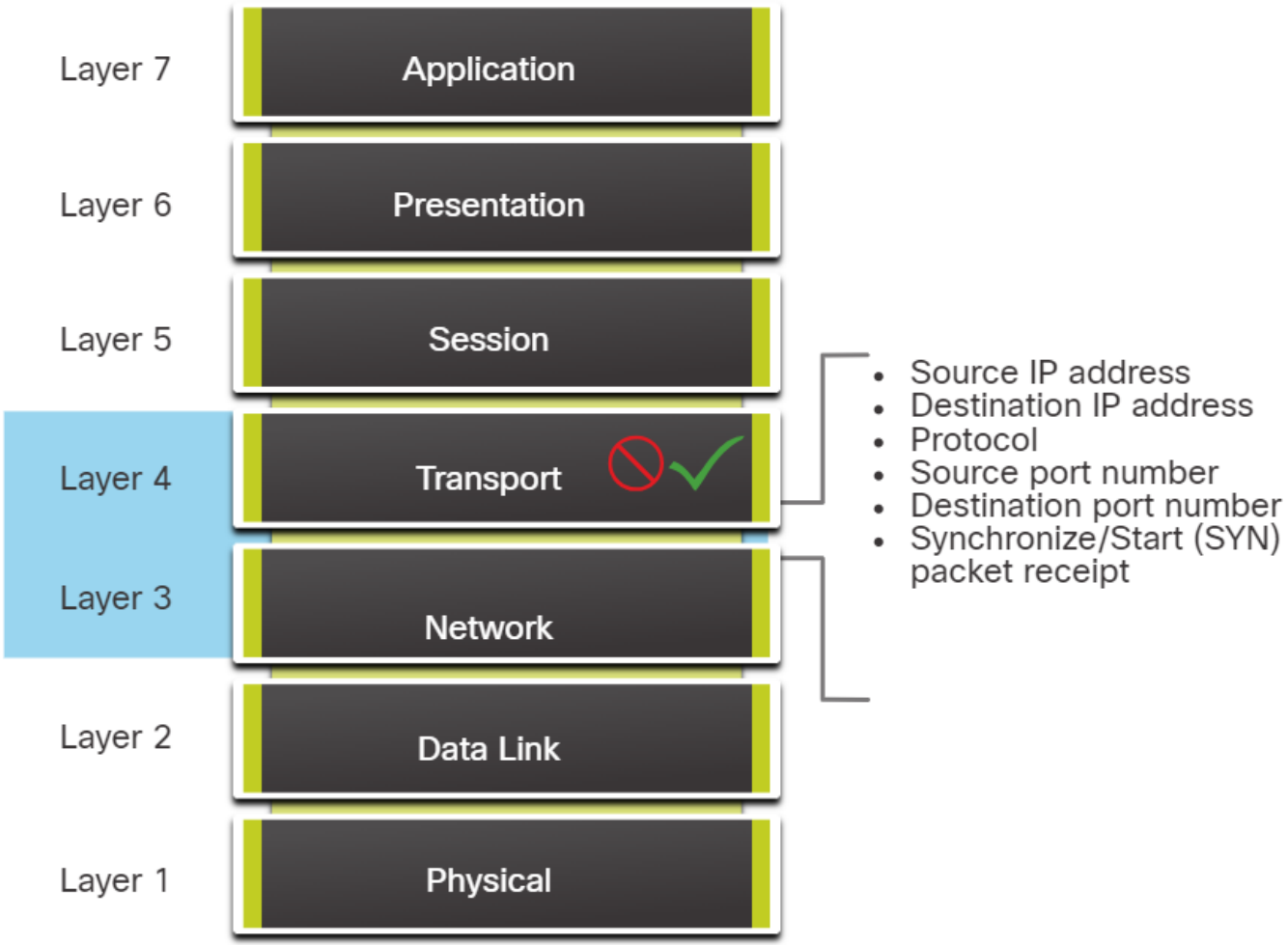
- En brandvägg följer fördefinierade regler för hur trafik får flöda
- Finns i flera olika varianter:
- **Host-baserade brandväggar**
  - T.ex. Windows-brandväggen
- **Mjukvarubrandväggar**
  - Cisco IOS firewall – Mjukvara på Cisco IOS, t.ex. Zone-Based Policy Firewall (ZPF)
  - Mjukvara via appliance/VM eller dyl. (t.ex. PfSense)
- **Dedikerade lösningar (hårdvarubrandväggar)**
  - Cisco ASA, Firepower, Checkpoint, FortiGate, Palo Alto, WatchGuard, etc.
- Beroende på funktion delas de också in i:

Olika typer av brandväggar (funktion)

- Packet Filtering (stateless)
- Stateful Firewall
- Application Firewall (Layer 7)
- Application Gateway Firewall
- Next Generation Firewall

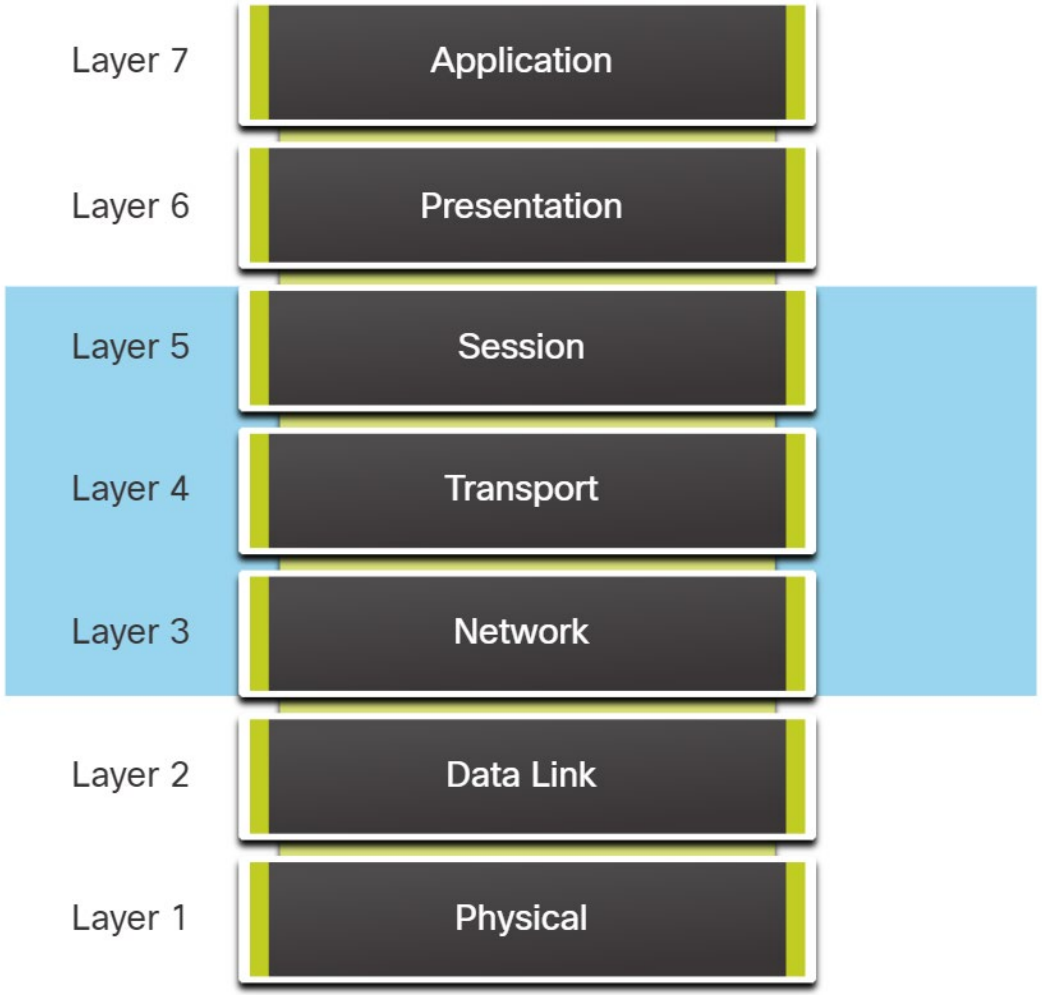
Packet Filtering Firewall

- Kallas även **stateless**
- Exempelvis enkla access-listor (ACL)
- **Egenskaper:**
  - Lager 3-4
- **Fördelar:**
  - Väldigt liten påverkan på prestanda
  - Enkla att implementera
  - Billiga
- **Nackdelar:**
  - ”Lätta” att lura, spoofing
  - Skyddar inte mot attacker på Lager 5-7



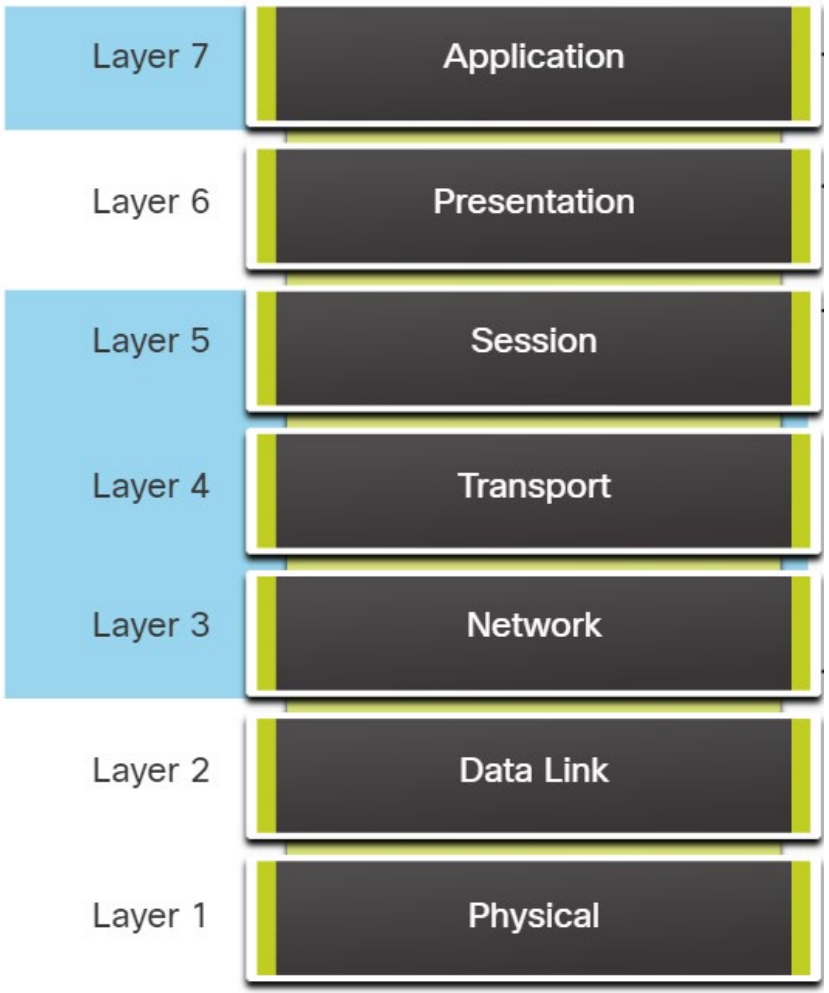
Stateful Firewall (SPI)

- **Stateful** innebär att…
- Exempelvis ZPF, ASA, FortiGate etc.
- **Egenskaper:**
  - Lager 3-(5) (finns även varianter upp till lager 7)
  - Bygger state-tabeller
- **Fördelar:**
  - Fortfarande hyfsat enkla med hyfsad prestanda
  - Tillåter endast tillbakatrafik
- **Nackdelar:**
  - Skyddar inte mot L7-attacker
  - UDP skickas inte stateful, finns därför svagheter där



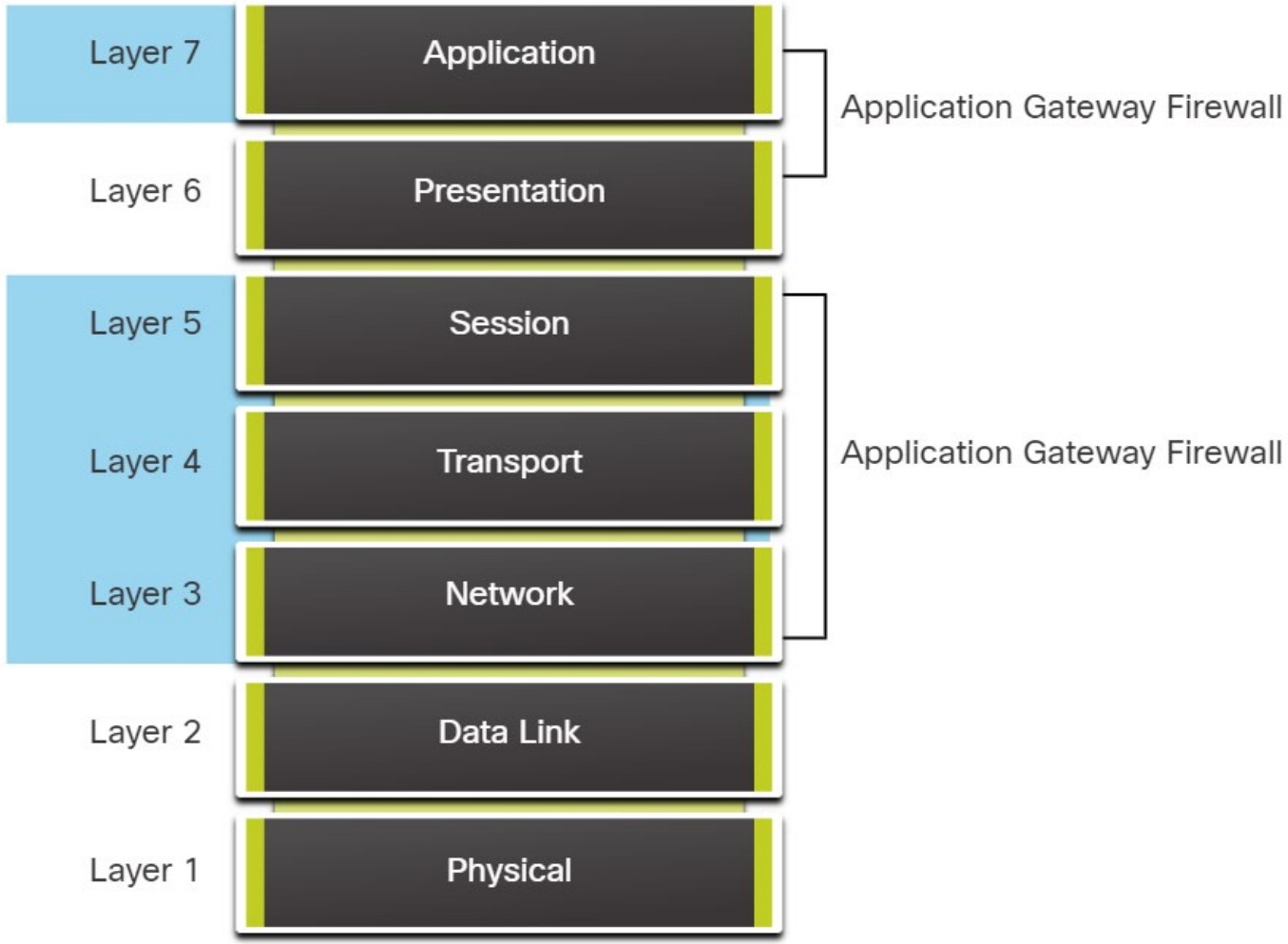
Application Firewall (L7 – Layer 7 Firewall)

- Stateful upp till applikationslagret
- **Egenskaper:**
  - Lager 3, 4, (5) och 7
- **Fördelar:**
  - Svår att spoofa
  - Ganska lätt att konfigurera
- **Nackdelar:**
  - Prestandakrävande
  - Tillåter endast applikationer som brandväggen känner till



Application Gateway Firewall (AGF)

- Kan t.ex. vara en **proxy** eller en **bastion**
- **Egenskaper:**
  - Lager 3, 4, 5 och 7
- **Fördelar:**
  - Väldigt bra kontroll på trafiken
- **Nackdelar:**
  - Prestandakrävande
  - Avancerad konfiguration



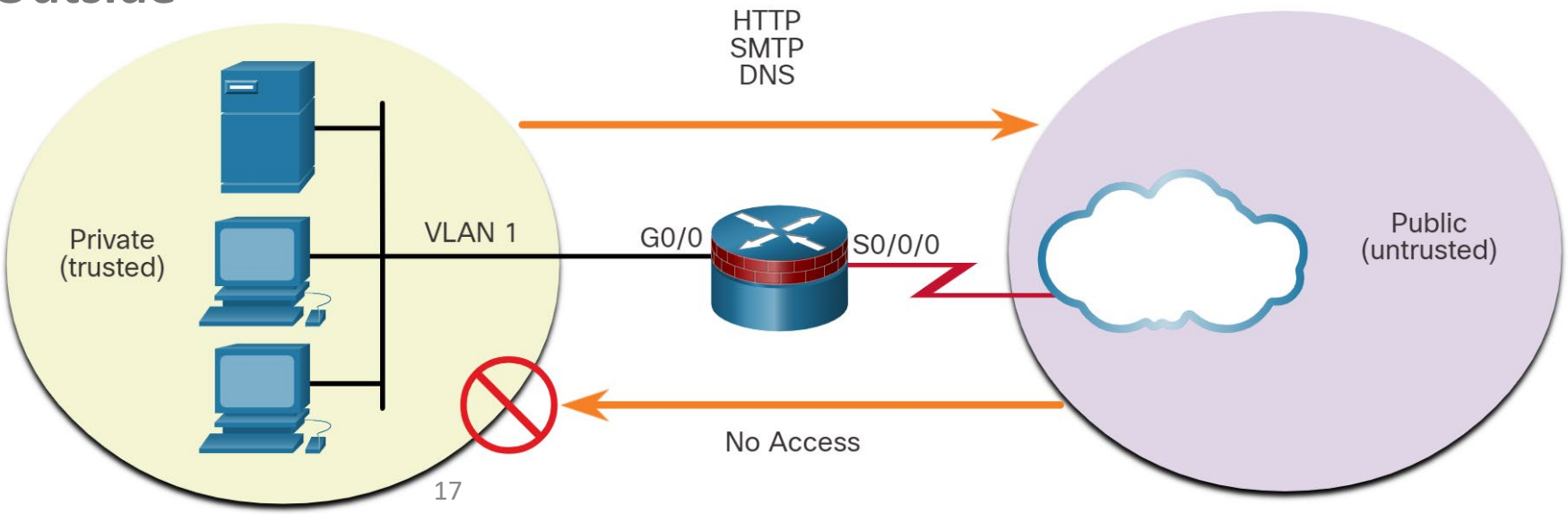
Next Generation (NG) Firewalls

- En modern brandvägg brukar kallas för NG (eller NGFW)
- **NGFW** använder flera olika funktioner för att öka säkerheten:
  - Integrerad intrångsprevention (IPS)
  - Finkornig filtrering inom applikationer
  - Filtrering av webb-sidor baserat på tillförlitlighet
  - Förebyggande funktioner mot cyberhot
  - Policys baserade på hot-nivån
  - (NAT, VPN, SPI)
- Ett exempel är Cisco ASA, Firepower, Checkpoint, FortiGate, etc.

Säker nätverksdesign

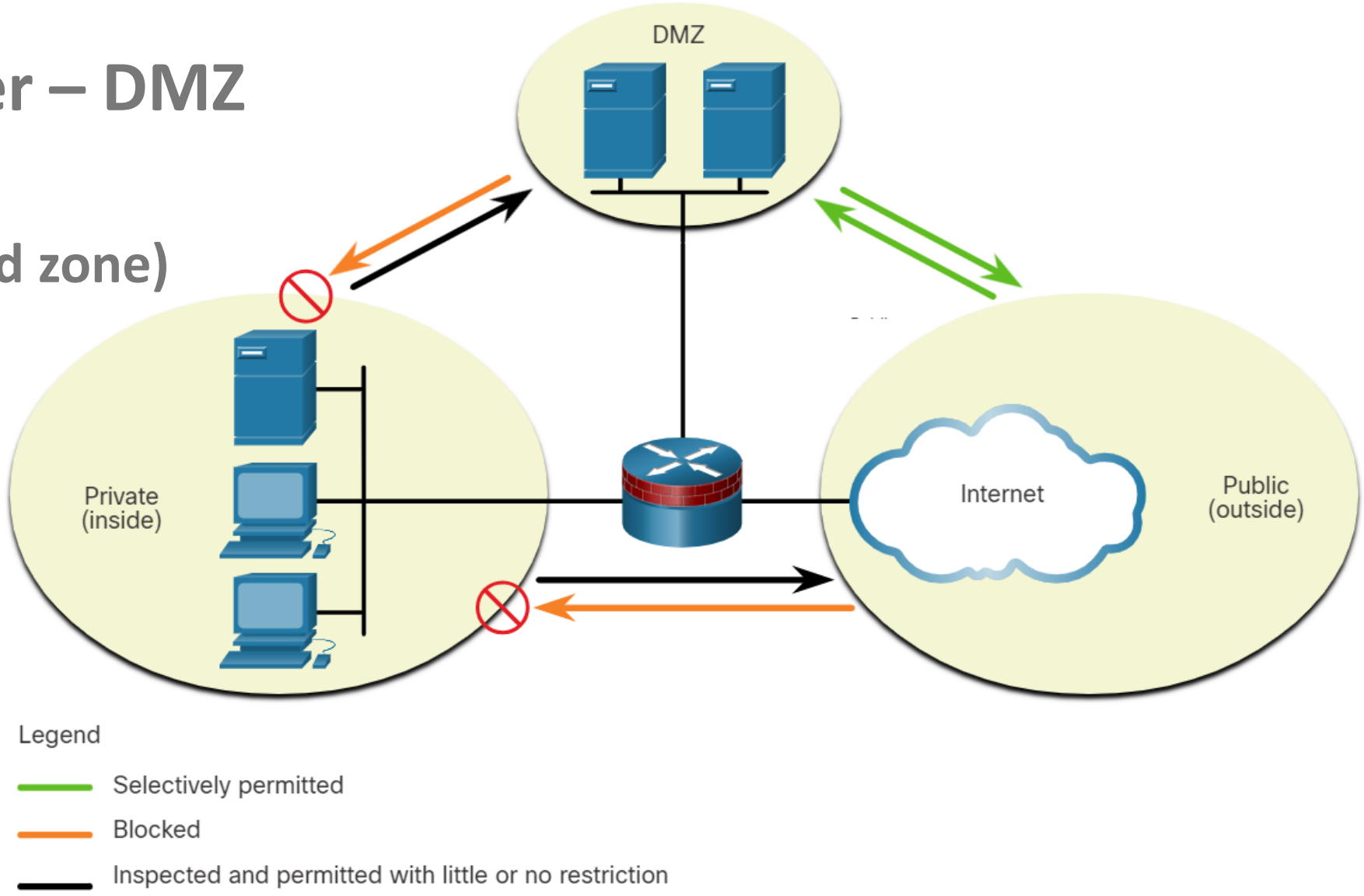
Brandväggszoner

- En brandvägg är ett skydd mellan olika zoner
- Som minst förekommer alltid två zoner:
  - **Private**, kallas även **Inside**
  - **Public**, kallas även **Outside**

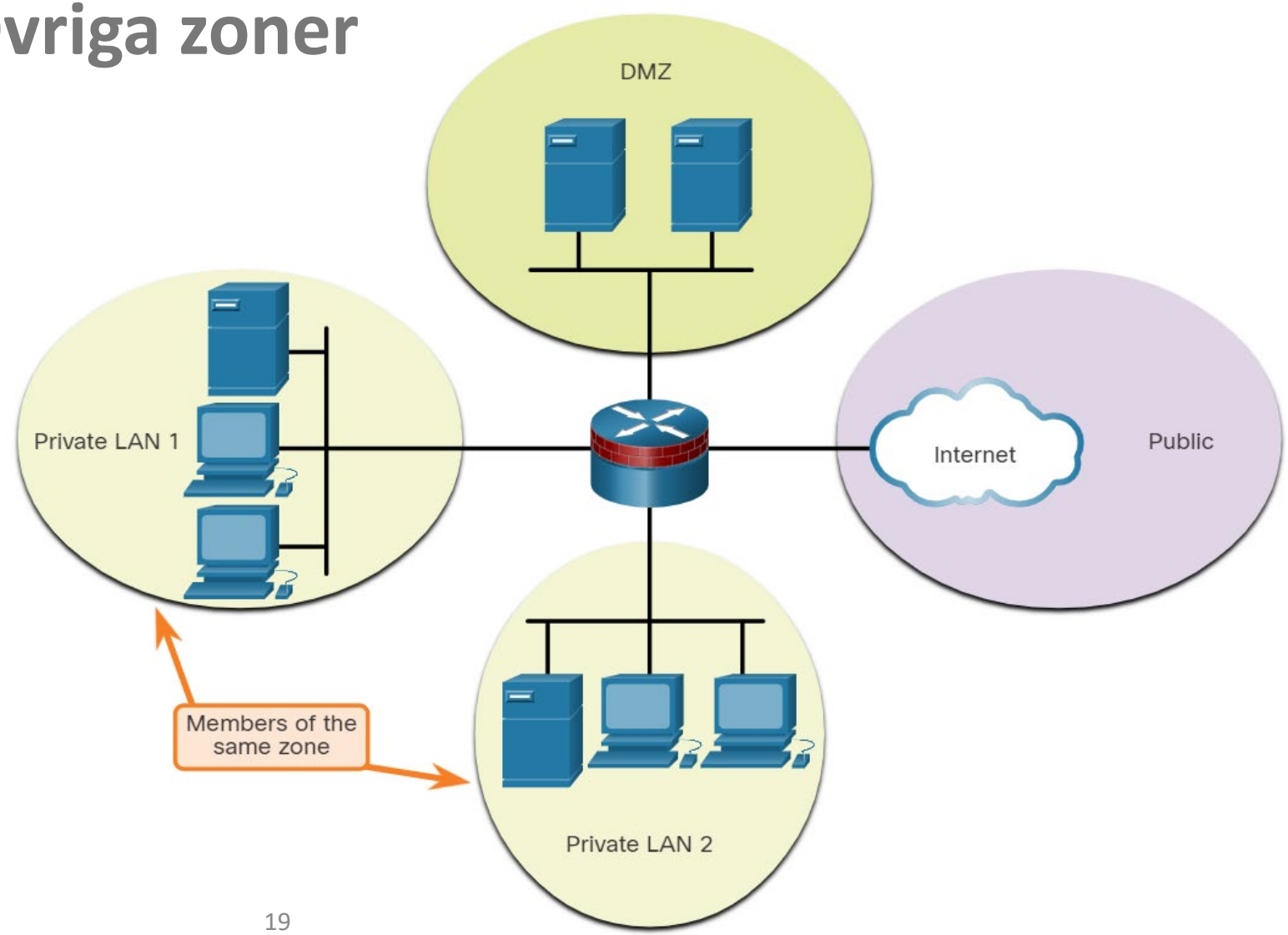


Brandväggszoner – DMZ

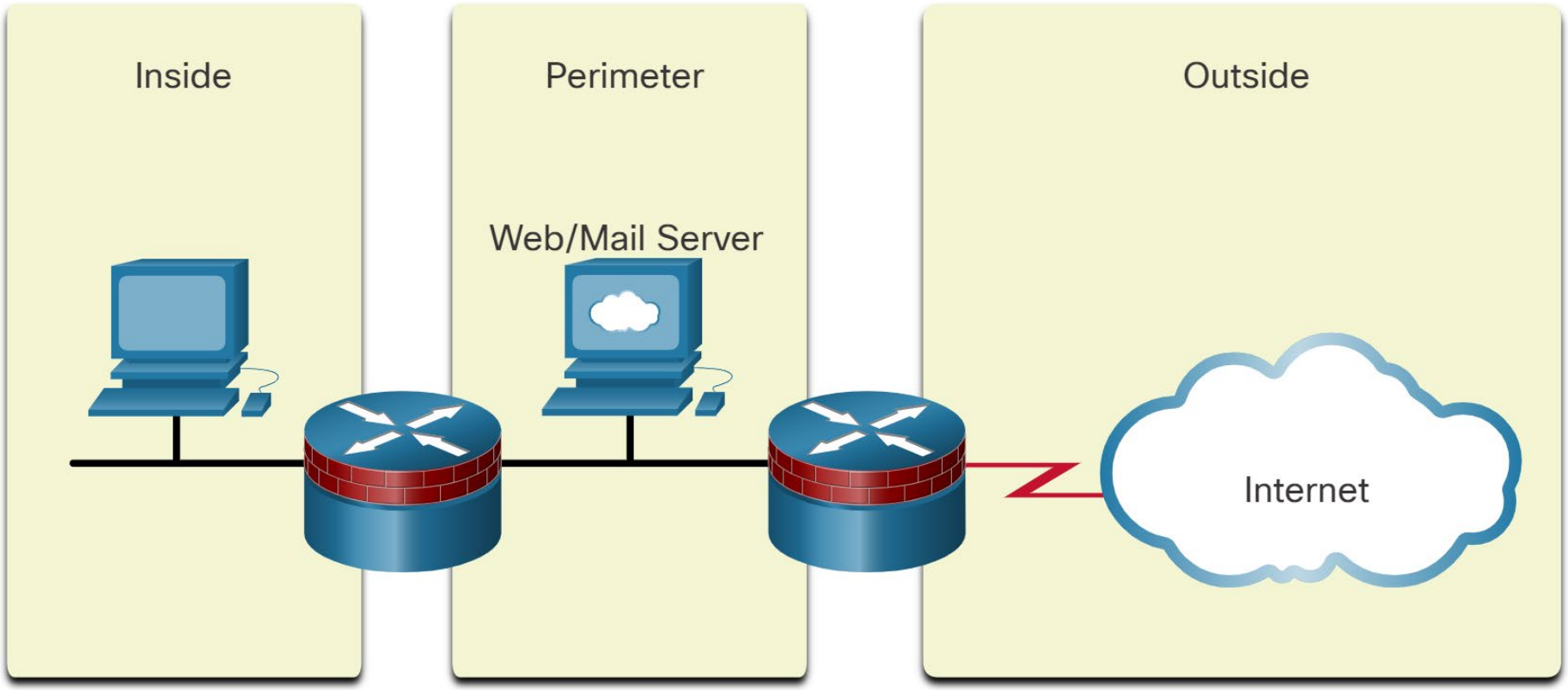
- DMZ (Demilitarized zone)



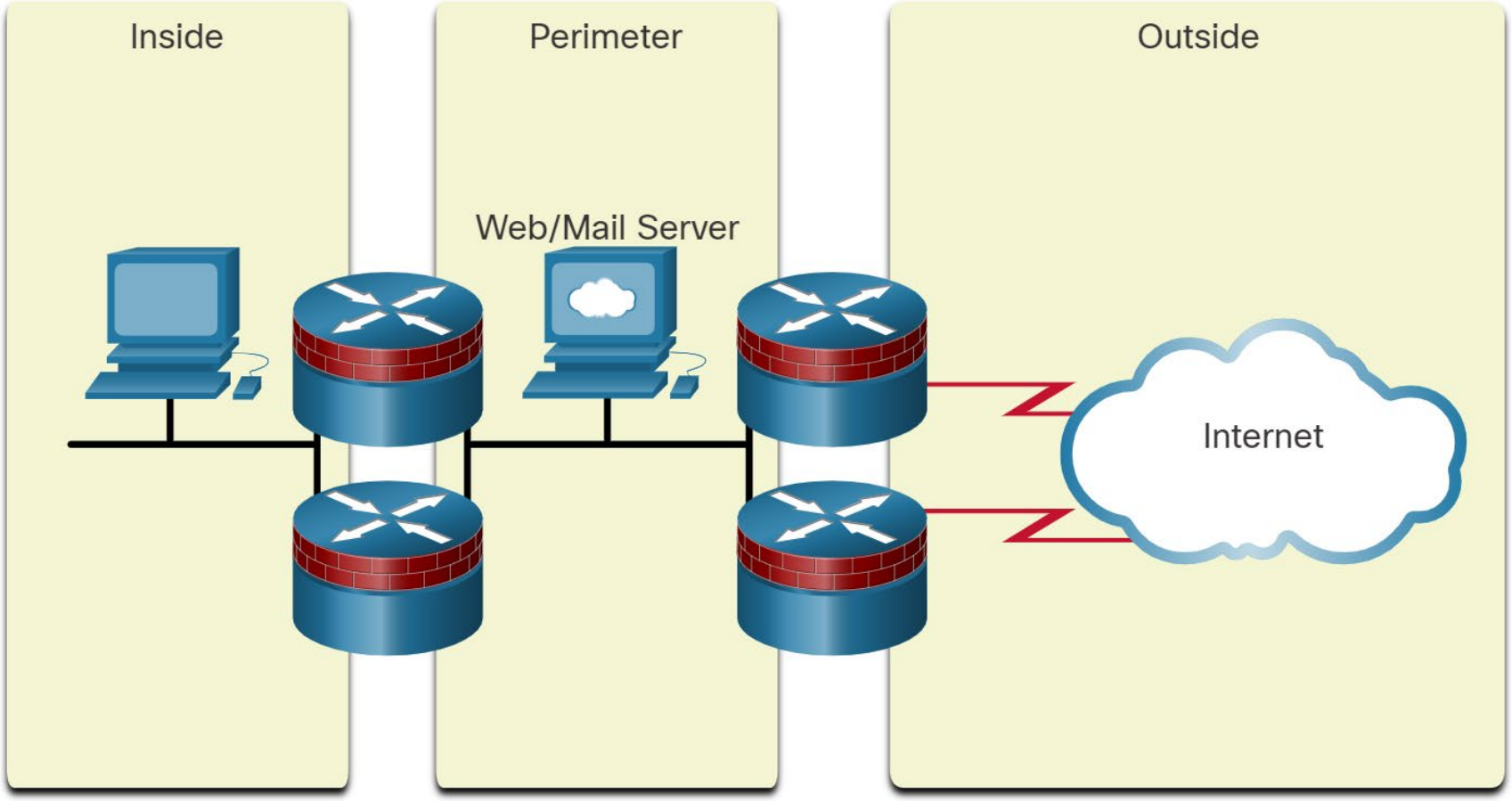
Brandväggszoner – Övriga zoner



Brandväggszoner – Perimeter



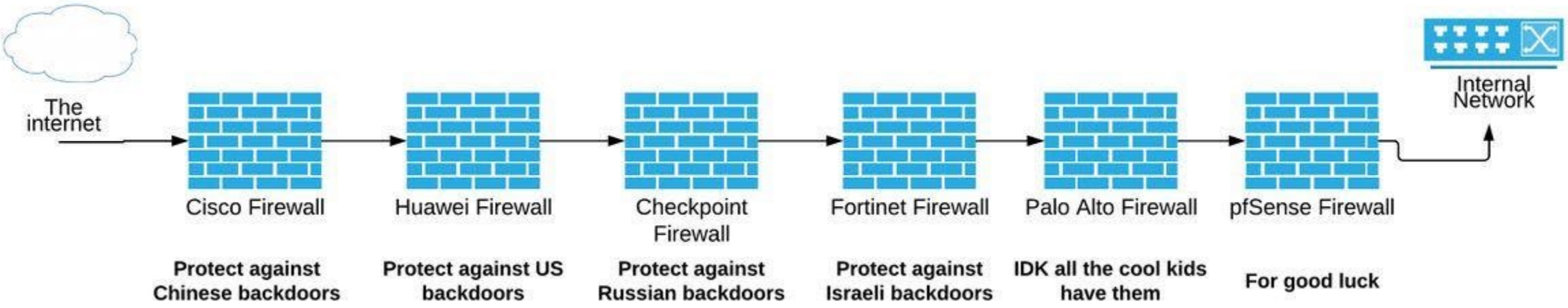
Brandväggszoner – Redundans



Best-practice

- Brandväggar skyddar inte mot allt!
- Använd brandväggar för att skydda mellan olika zoner med olika skyddsnivåer, inte inom en zon
- Förbjud all trafik som standard, tillåt endast nödvändig trafik (zero-trust)
- Hindra fysisk tillgång till brandväggen
- Övervaka och granska brandväggsloggar (t.ex. med ett SIEM)
- Ha en rutin för konfigurationsändringar (change mangement)

”Defense-in-depth”



https://www.reddit.com/r/networkingmemes/comments/1an4r4p/hopefully_we_will_get_rid_of_cves/

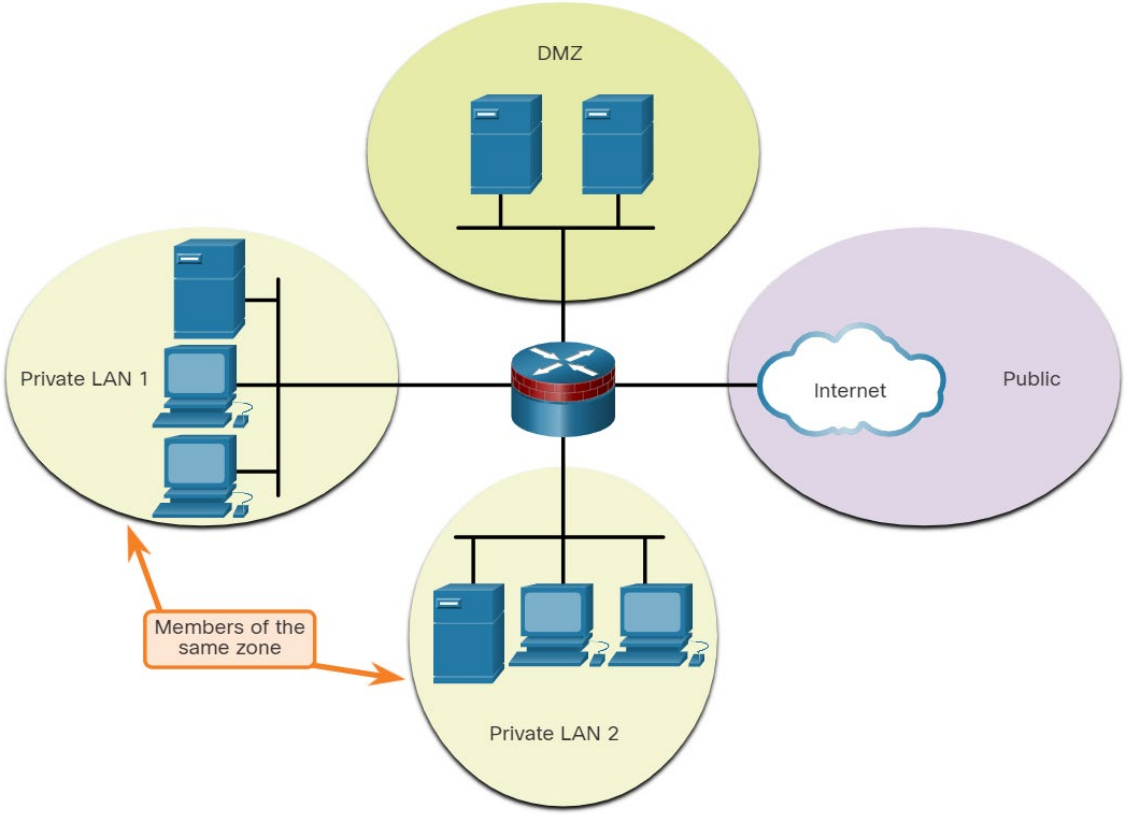
Ciscos brandväggar

ZPF -> ASA -> Firepower

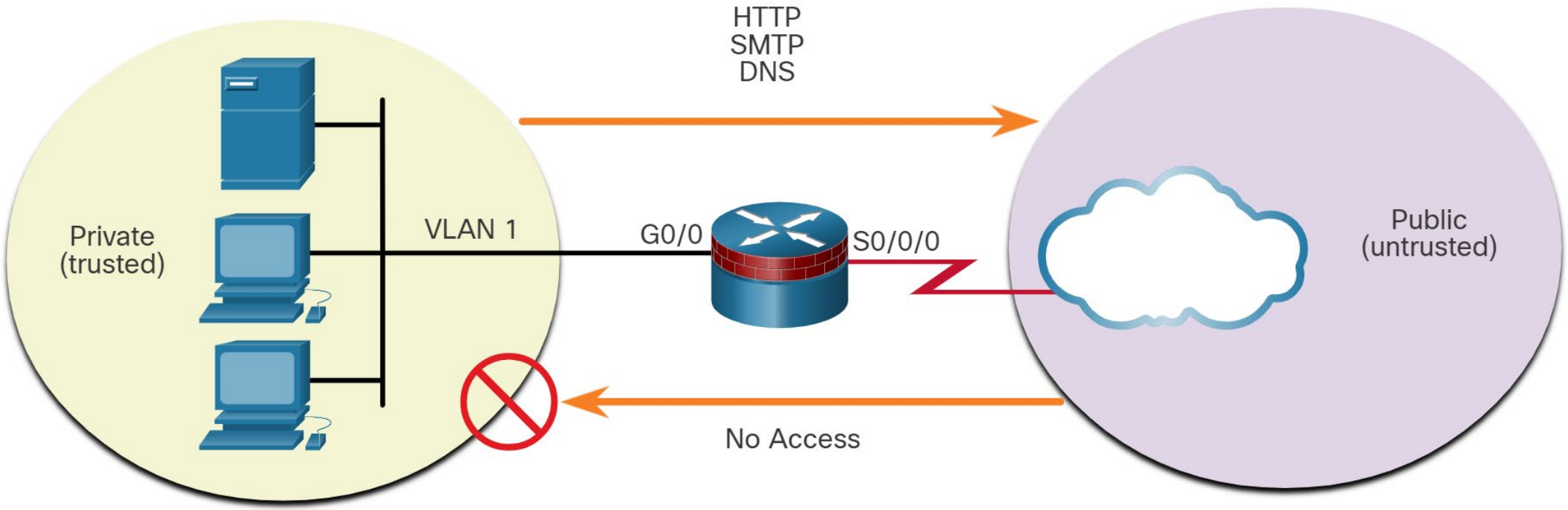
Zone-Based Policy Firewalls (ZPF)

- Modernaste formen av en brandvägg på Cisco IOS där man definierar olika säkerhetszoner
- Tre regler:
  - **Pass**
  - **Drop**
  - **Inspect**

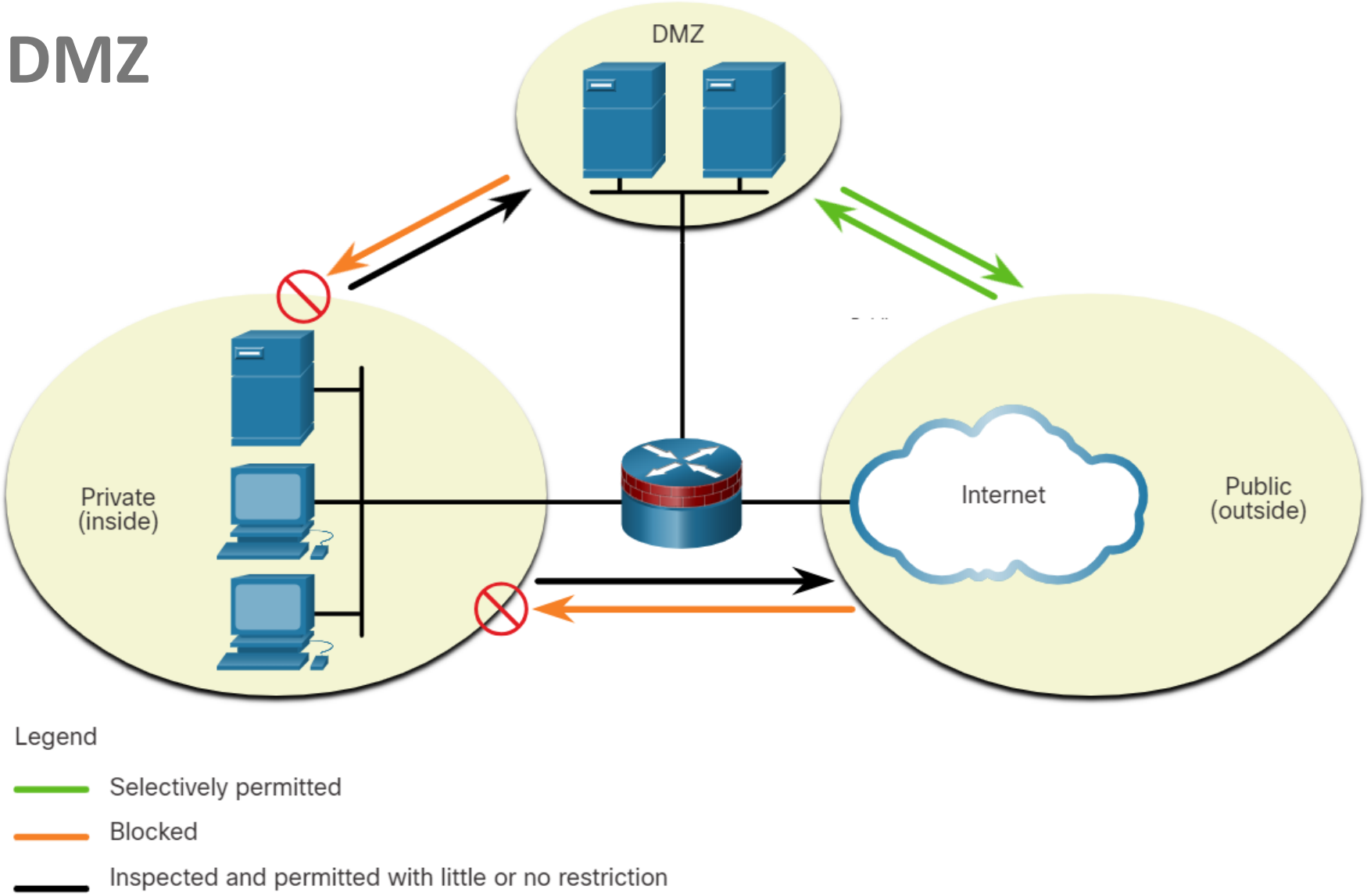
Skillnad?



Zoner: Private & Public

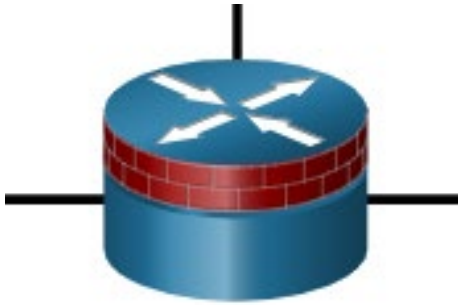


Zoner: DMZ


DMZ
Private
(inside)
Internet
Public
(outside)
Legend
Selectively permitted
Blocked
Inspected and permitted with little or no restriction

Zoner: Self-zone

- Som standard är all trafik förbjuden mellan olika zoner
- **Undantag:** Trafik till och från **self-zone** tillåts



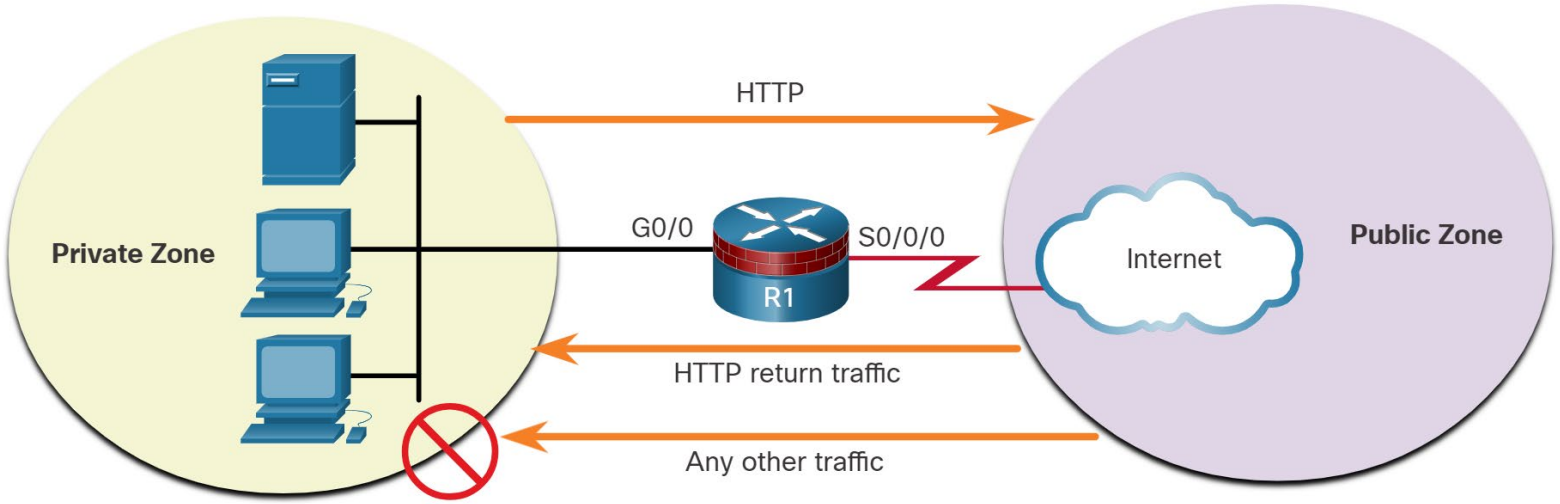
Varför ZPF?

- Enkelt att använda (om man vill säkra ett stort nätverk)
  - Här blir ACL ohanterligt
- Enkelt att läsa (enligt Cisco…) eftersom den använder C3PL
  - Cisco Common Classification Policy Language
  - Används även för QoS, till viss del VPN och även på Cisco ASA
- Skalbart för växande nätverk
- **Nackdelar:**
  - Till en början är konfigurationen mer komplicerad jämfört med en ACL
  - För små nätverk tappar man tidsvinsten

Konfiguration av ZPF – 5 steg

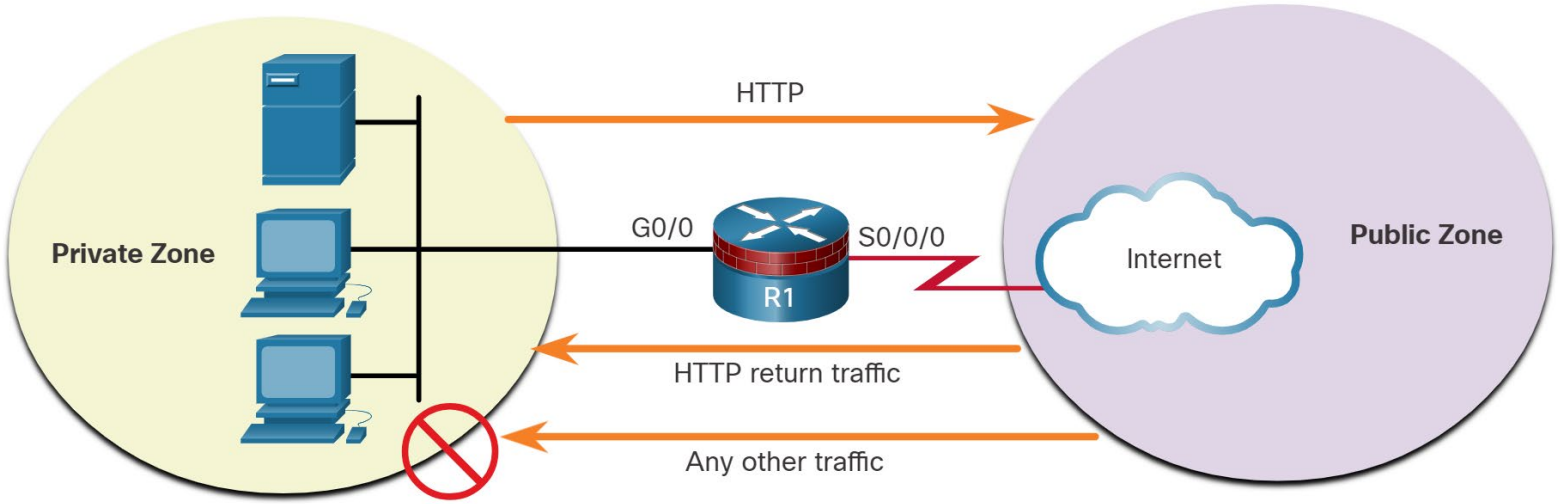
- **Steg 1:** Skapa zonerna
- **Steg 2:** Identifiera trafik med hjälp av en **class-map**
- **Steg 3:** Definiera vad som ska hända med en **policy-map**
- **Steg 4:** Identifiera ett **zon-par** (t.ex. *INSIDE* → *OUTSIDE*) och applicera en policy map (**service-policy**)
- **Steg 5:** Tilldela zonerna på interface

Konfigurera ZPF – Steg 1: Skapa zoner



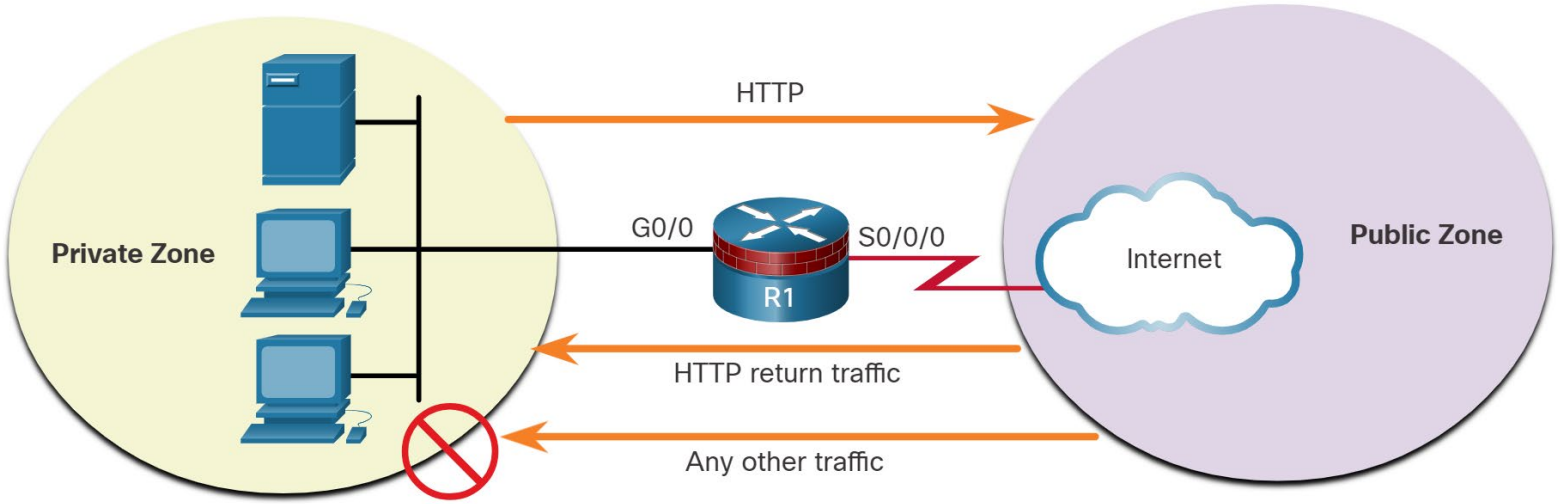

```
R1(config)# zone security PRIVATE
R1(config-sec-zone)# exit
R1(config)# zone security PUBLIC
R1(config-sec-zone)# exit
```

Konfigurera ZPF – Steg 2: Identifiera trafik



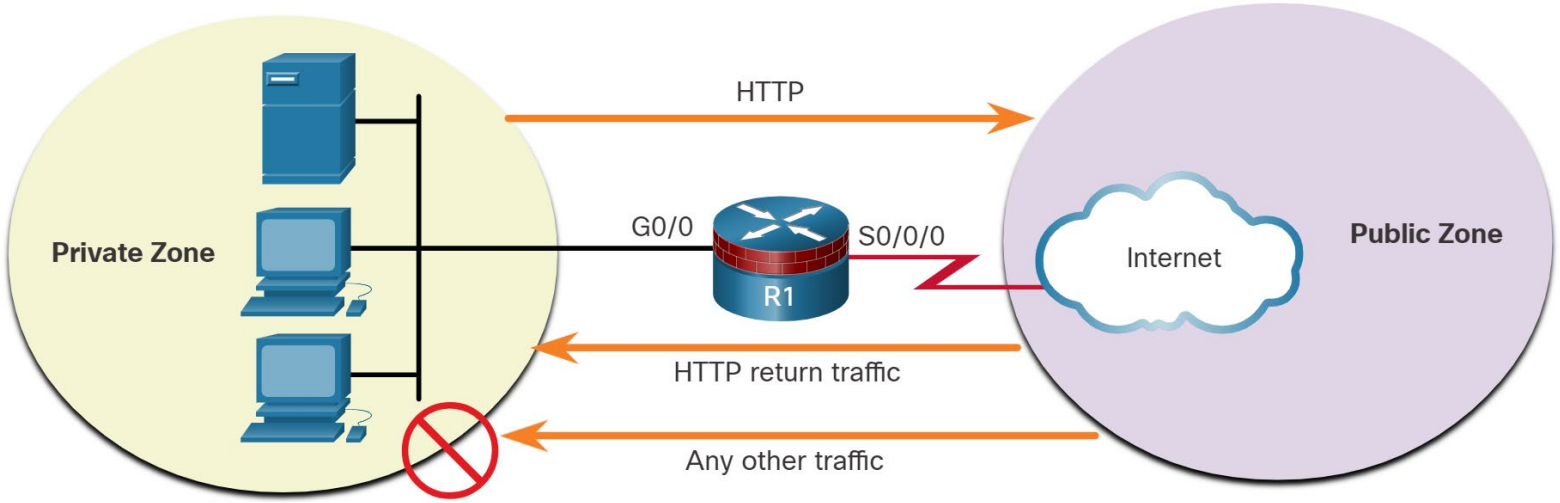

```
R1(config)# class-map type inspect match-any HTTP-TRAFFIC
R1(config-cmap)# match protocol http
R1(config-cmap)# match protocol https
R1(config-cmap)# match protocol dns
```

Konfigurera ZPF – Steg 3: Definiera en gärning



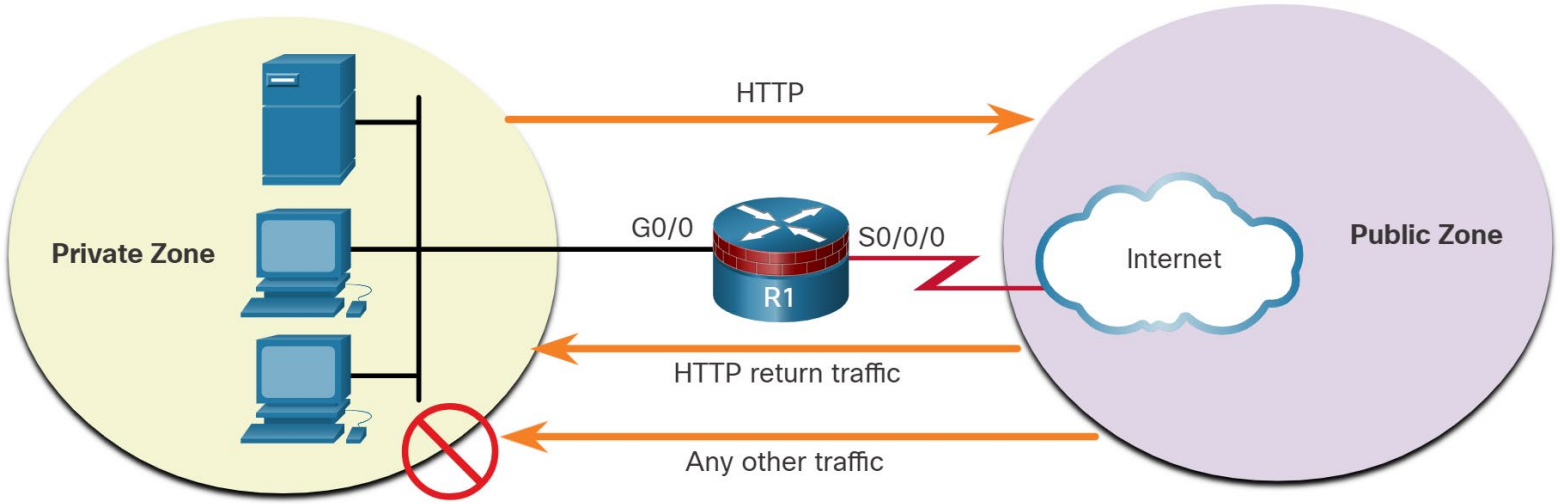

```
R1(config)# policy-map type inspect PRIV-TO-PUB-POLICY
R1(config-pmap)# class type inspect HTTP-TRAFFIC
R1(config-pmap-c)# inspect
```

Konfigurera ZPF – Steg 4: Identifiera Zone-Pair och sätt Service-Policy




```
R1(config)# zone-pair security PRIV-PUB source PRIVATE destination PUBLIC
R1(config-sec-zone-pair)# service-policy type inspect PRIV-TO-PUB-POLICY
```

Konfigurera ZPF – Steg 5: Tilldela zoner




```
R1(config)# interface gi0/0
R1(config-if)# zone-member security PRIVATE
R1(config-if)# exit
R1(config)# interface s0/0/0
R1(config-if)# zone-member security PUBLIC
```

Konfigurera ZPF – Sammanfattning

```
! Skapa zoner
R1(config)# zone security INSIDE
R1(config)# zone security OUTSIDE

! Skapa class maps
R1(config)# class-map type inspect match-any MYCLASS
R1(config-cmap)# match protocol icmp

! Skapa policy map
R1(config)# policy-map type inspect MYPOLICY
R1(config-pmap)# class type inspect MYCLASS
R1(config-pmap-c)# inspect

! Skapa zonpar och service-policy
R1(config)# zone-pair security IN2OUT source INSIDE destination OUTSIDE
R1(config-sec-zone-pair)# service-policy type inspect MYPOLICY

! Koppla interface till zoner
R1(config)# interface f0/0
R1(config-if)# zone-member security INSIDE
R1(config-if)# interface f0/1
R1(config-if)# zone-member security OUTSIDE
```

Konfigurera ZPF – Verifiera konfigurationen

- Visa class-maps:
  - **show class-map type inspect**
- Visa policy-maps:
  - **show policy-map type inspect**
- Visa zon-par:
  - **show zone-pair security**
- Visa aktiva sessioner mellan zone-pair:
  - **show policy-map type inspect zone-pair sessions**

Min personliga favorit!

Regler för ZPF

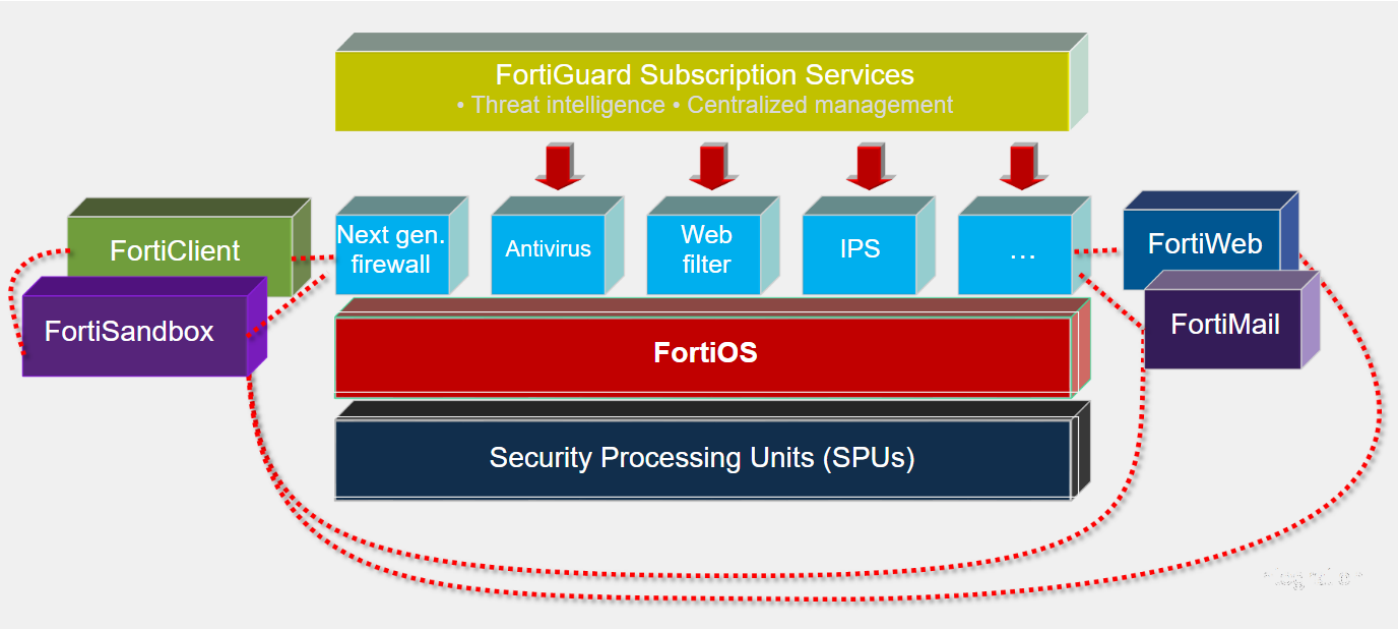
- Trafik **mellan olika zoner** är som standard blockerat
  - Samma tankesätt som i ACL (implicit deny)
  - Undantag: Till och från **self-zone** tillåts som standard
- Trafik i **samma zon** är som standard tillåtet
- Trafik mellan en zon till ett interface **utan zon** är inte tillåtet
- Går att kombinera med **ACL**:
  - ACL appliceras **efter ZPF** för **ingående trafik**
  - ACL appliceras **före ZPF** för **utgående trafik**

Cisco Adaptive Security Appliance (ASA) och Firepower

- Tidigare hade Cisco en enhet som hette PIX (**P**rivate **I**nternet e**X**change), end of sale 2008
- PIX hade ”enklare” funktioner som brandvägg, NAT, etc.
- Efter PIX tog ASA över samma segment, ASA (Adaptive Security Appliance) innehåller samma funktioner som PIX med flera tillägg
  - Smartare brandvägg, IPS, VPN (S2S, RA, SSL, etc.), high availability
- ASA körs fortfarande i många miljöer, men i nya installationer körs istället Cisco Firepower med integrerad IPS
- ASA är en del av NetAcad-materialet, men vi har tagit bort det

FortiGate

FortiGate



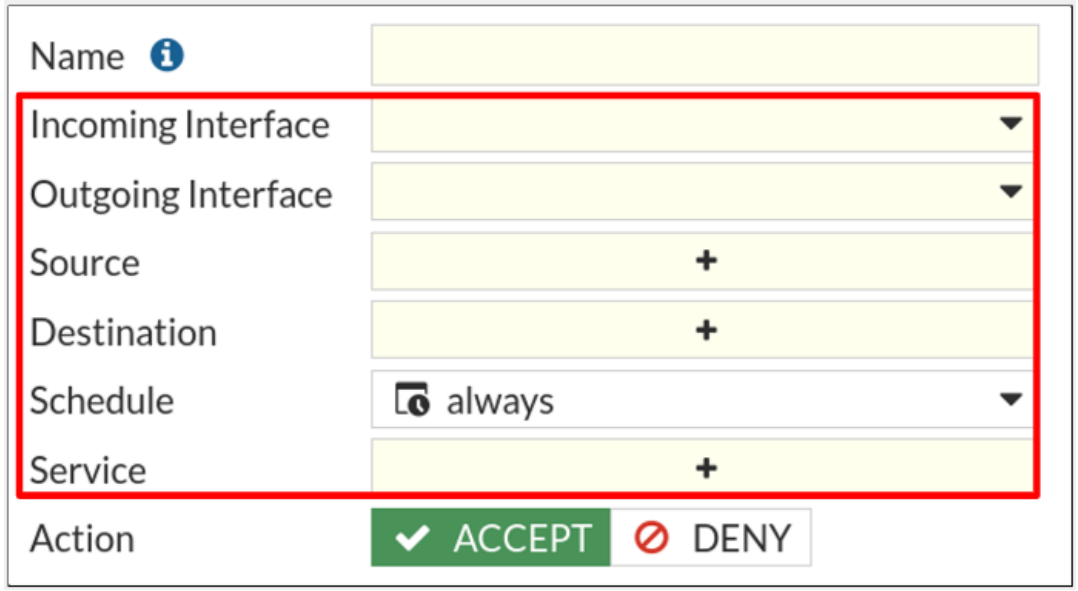
- **Grundtanke:** Allt styrs via FortiGate, likt en controller över nätverket, Fortigate agerar också router för nätverket

Initial konfiguration på FortiGate

- Nås på 192.168.1.99/24 från port1 som standard
- Följande protokoll är då aktiverade: ping, https, ssh, dhcp
- Standard-inlogg är: admin/(blank) (lösenord kan även vara **cisco**)
- Det går att nå enheten via CLI, notera dock att *baud rate* kan skilja från Cisco

Brandväggsregler

- Likt en ACL:
  - Börjar i toppen och går ur listan om den hittar en match
  - Om det inte finns en matchning -> **implicit deny**
  - Bygger på objekt
- Zoner kan användas för att gruppera flera fysiska interface, notera att alla äldre regler försvinner
- Source/destination går att göra väldigt fingranulärt (ner på AD-användare)

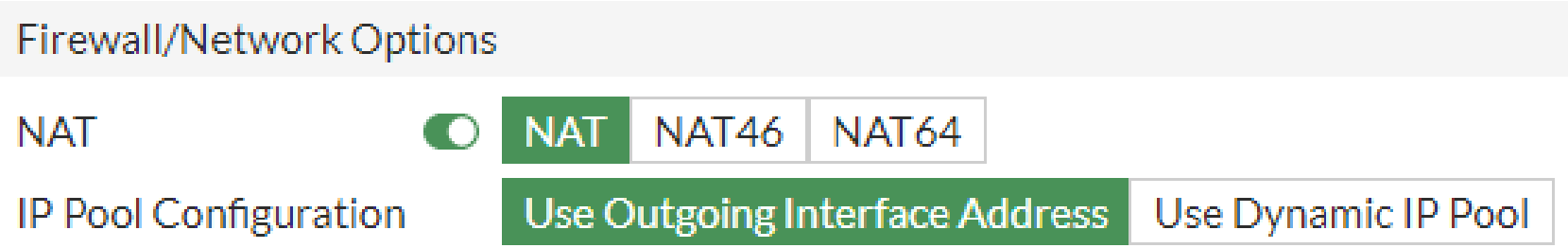


Brandväggsregler – Security profiles

- Är olika funktioner som går att lägga till i brandväggsregler:
  - Antivirus
  - Webbfilter
  - DNS-filter
  - IPS
  - SSL Inspection, analys av krypterad trafik, (nästa)

NAT

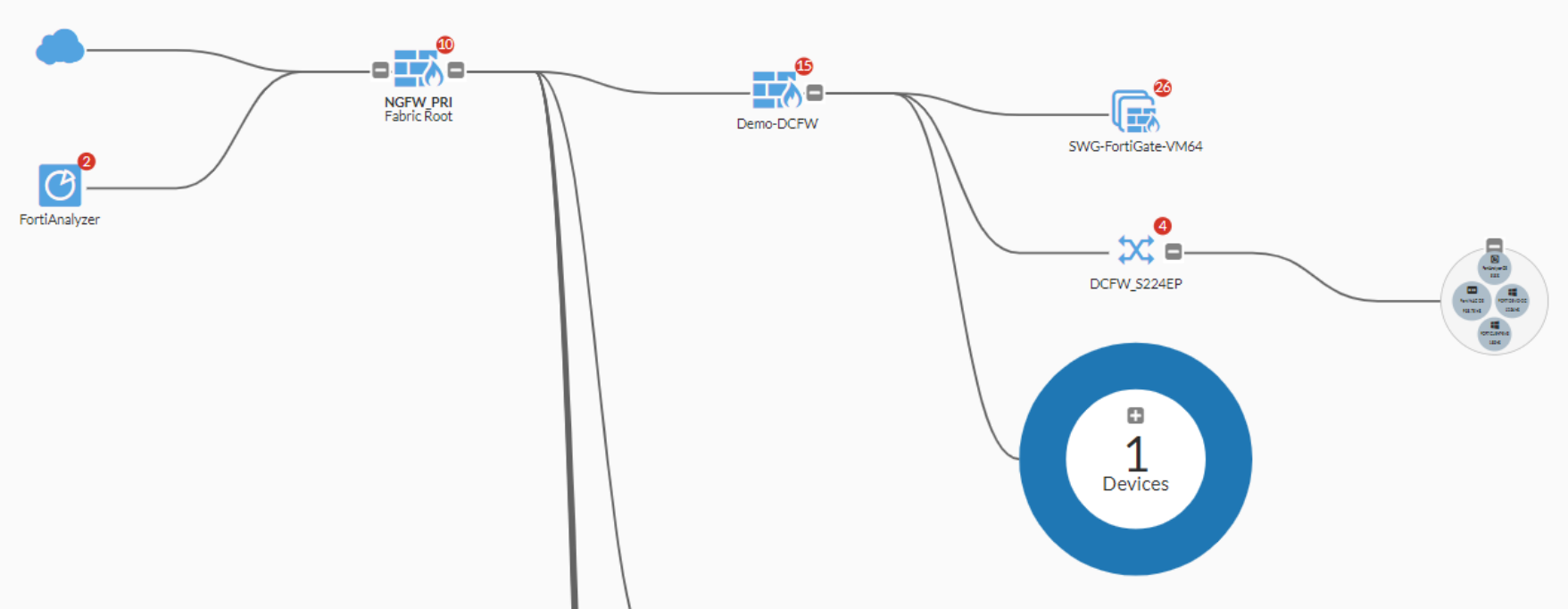
- Delar upp **PAT** och **Statisk NAT**
- **PAT** läggs till under brandväggsregler och kallas kort och gott: **NAT**



- **Statisk NAT** läggs till under fliken **Virtual IPs**

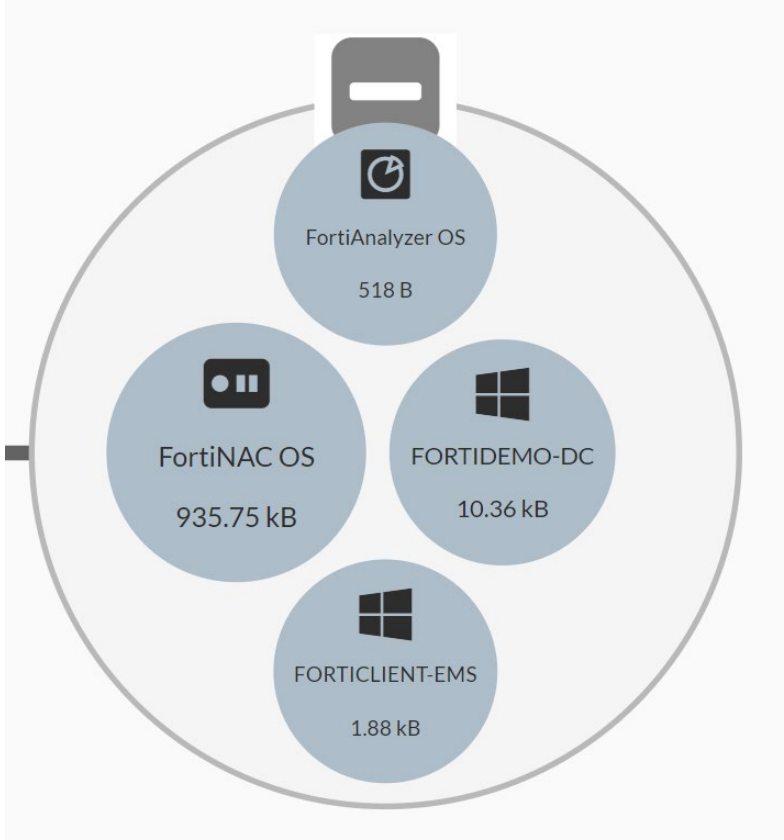
Security Fabric

- **Grundtanke:** Allt styrs via FortiGate, likt en controller över nätverket
- Hela nätverket går också att styra från ett gränssnitt, hela nätverket blir en **Security Fabric** där man har synlighet i hela nätverket från klient till brandvägg



FortiClient

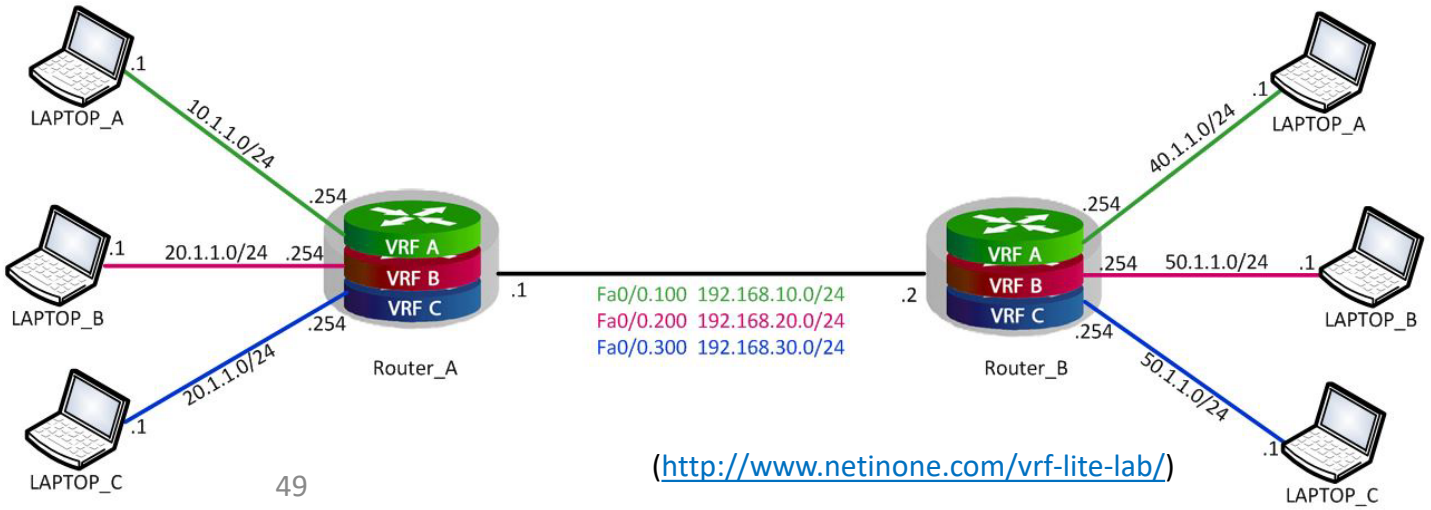
- Med FortiClient får man transparens genom hela nätverket då FortiGate även vet vad som händer på klienten
- Klienten blir en del av Security Fabric
- Klienten kan lätt ansluta till VPN
- Klienten får övriga säkerhetsfunktioner som sandboxing, URL filter, etc.



VRF

VDOM och VRF

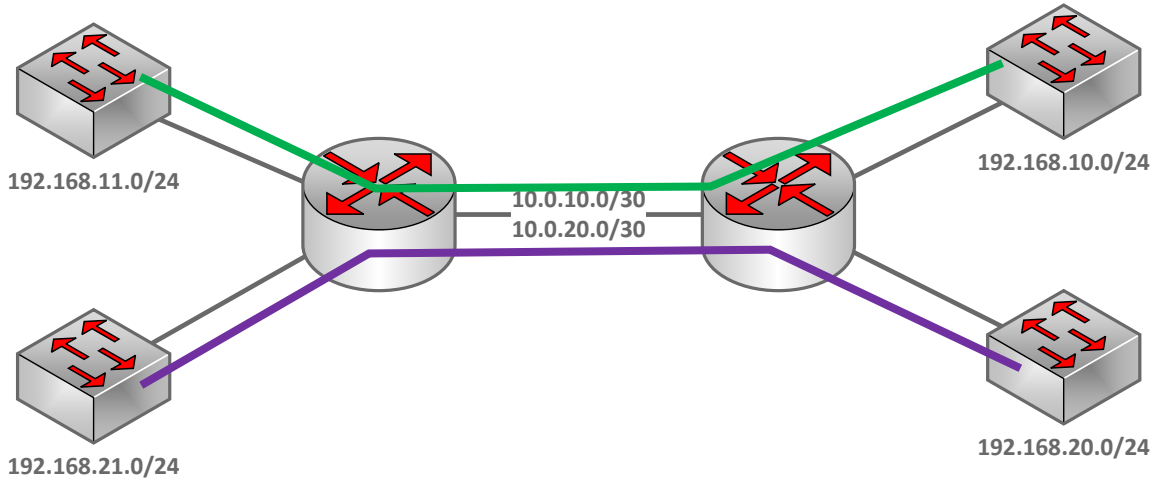
- VRF introducerades med MPLS (för SP)
- Eftersom det var så användbart i sig självt tog man fram en variant som fungerar utan MPLS i mindre miljöer, **VRF Lite**
- Fungerar exempelvis i ett datacenter där man vill dela upp (segmentera) olika kunder



(http://www.netinone.com/vrf-lite-lab/)

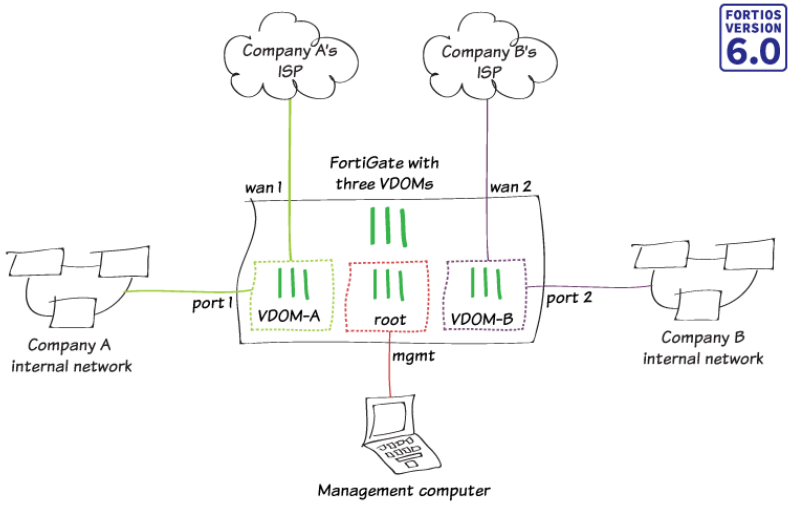
VRF Lite – Resultat

- Två helt separata nätverk, men som ändå körs på samma fysiska enheter
- Att jämföra med funktionen som VLAN ger switchar, fast för routrar
- För att testa VRF används
  ping vrf *VRF_namn*



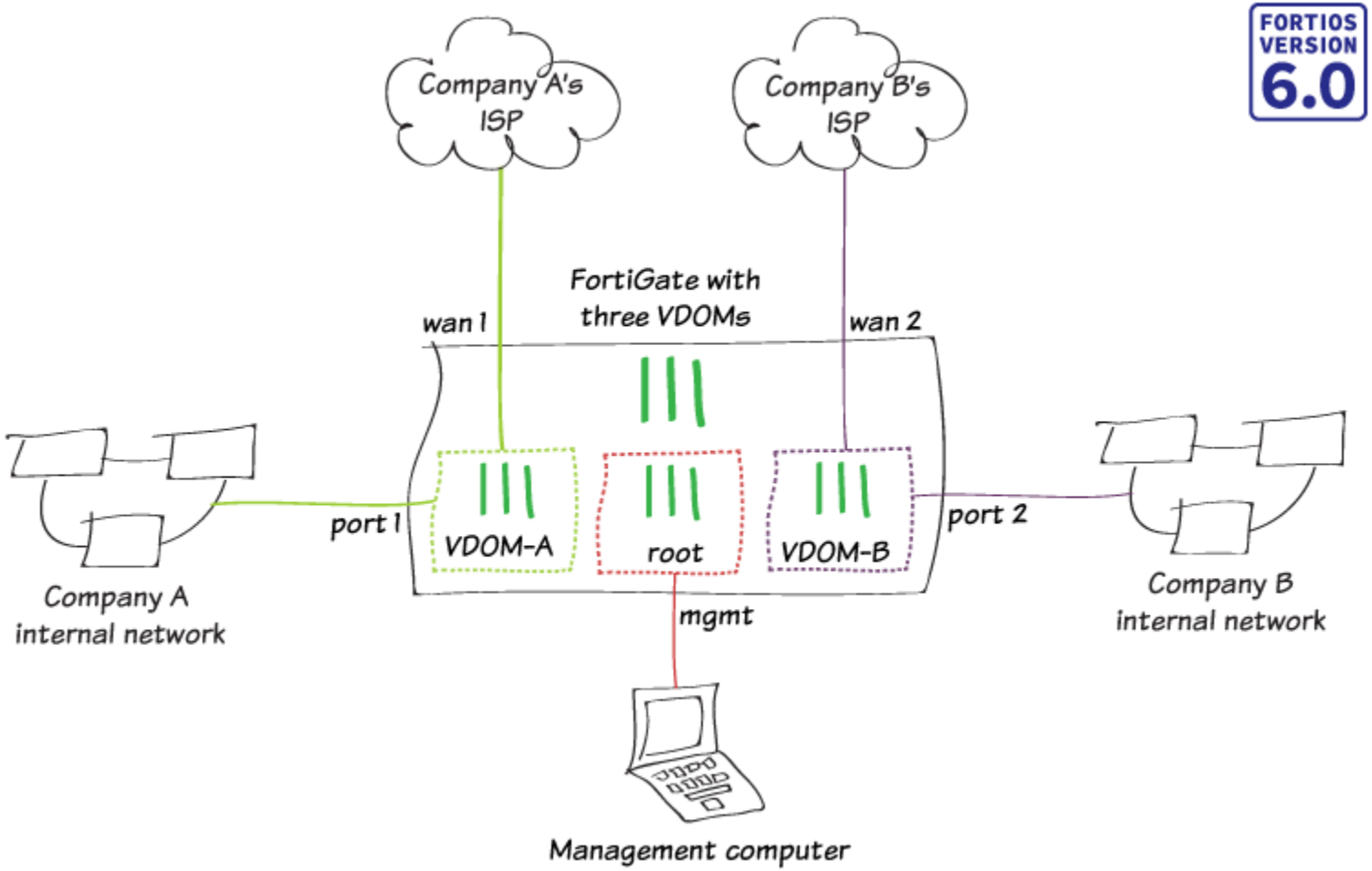
VRF, Context, VDOM

- Motsvarande teknik kallas i Cisco ASA för **Context** och i FortiGate **VDOM**
- Tekniken låter oss köra flera instanser av en brandvägg med olika (och överlappande) routingtabeller
- Kan t.ex. användas för ett konsultbolag som använder en gemensam brandvägg för flera kunder



VDOM

FORTIOS VERSION 6.0



kahoot.it

JÖNKÖPING UNIVERSITY

School of Engineering